

Portafolio De Ciberseguridad

Laboratorio de análisis básico de vulnerabilidades en una aplicación web

OWASP Juice Shop - Proyecto práctico de ciberseguridad

Jennifer Gabriela Rodríguez Jiménez

Entorno de laboratorio - Ubuntu 22.04.5 LTS · Docker · VMware

Septiembre 2026

Laboratorio: Análisis básico de vulnerabilidades en una aplicación web

Introducción

La ciberseguridad es fundamental para proteger la información, los sistemas y las aplicaciones frente a diferentes tipos de amenazas. Para comprender mejor estos riesgos, no basta con conocer la teoría; también es necesario realizar prácticas en entornos controlados que permitan observar cómo pueden presentarse determinadas vulnerabilidades. En este proyecto se desarrolló un laboratorio práctico utilizando una máquina virtual con Ubuntu 22.04.5 LTS, Docker y la aplicación vulnerable OWASP Juice Shop. El objetivo fue identificar y analizar algunas vulnerabilidades básicas de seguridad en una aplicación web, documentando el proceso, los resultados obtenidos, los riesgos asociados y algunas recomendaciones de seguridad. Todas las pruebas fueron realizadas exclusivamente dentro de un entorno local y controlado, con fines educativos.

Objetivo general

Desarrollar un laboratorio práctico para identificar y analizar vulnerabilidades básicas de seguridad en una aplicación web, utilizando OWASP Juice Shop dentro de un entorno controlado, documentando el procedimiento, los resultados, los riesgos y las recomendaciones de seguridad correspondientes.

Objetivos específicos

- Configurar una máquina virtual con Ubuntu 22.04.5 LTS para realizar prácticas de ciberseguridad.
- Instalar y utilizar Docker como plataforma para ejecutar aplicaciones en contenedores.
- Implementar OWASP Juice Shop como aplicación web vulnerable para fines educativos.
- Familiarizarse con comandos básicos de Linux y Docker.
- Realizar pruebas básicas de seguridad sobre una aplicación web en un entorno controlado.

- Identificar vulnerabilidades relacionadas con autenticación, inyección y manejo de errores.
- Analizar el posible impacto de las vulnerabilidades encontradas.
- Documentar el proceso y los resultados obtenidos.
- Proponer recomendaciones para reducir los riesgos identificados.
- Generar evidencia práctica que pueda formar parte de un portafolio inicial de ciberseguridad.

Alcance y entorno controlado

El laboratorio se realizó únicamente sobre una aplicación vulnerable instalada de manera local dentro de una máquina virtual. Las pruebas no fueron realizadas sobre páginas web, servidores, cuentas o sistemas de terceros. El alcance del proyecto comprende la configuración del sistema operativo, instalación y utilización de Docker, implementación de OWASP Juice Shop, identificación de vulnerabilidades, realización de pruebas controladas, análisis básico de riesgos y elaboración de recomendaciones de seguridad. Este enfoque permite practicar técnicas de seguridad de manera responsable y sin afectar sistemas reales.

Herramientas utilizadas

Herramienta	Uso
VMware	Creación y ejecución de la máquina virtual
Ubuntu 22.04.5 LTS	Sistema operativo utilizado para el laboratorio
Docker	Ejecución de la aplicación vulnerable mediante un contenedor
OWASP Juice Shop	Aplicación web vulnerable utilizada para las pruebas
Navegador web	Interacción con la aplicación y realización de las pruebas

Configuración del laboratorio

El laboratorio se desarrolló utilizando una máquina virtual en VMware con Ubuntu 22.04.5 LTS. Para preparar el entorno se actualizó el sistema operativo mediante:

```
sudo apt update
```

Posteriormente se instaló Docker utilizando:

```
sudo apt install docker.io -y
```

Se habilitó el servicio de Docker mediante:

```
sudo systemctl enable --now docker
```

Luego se verificó su funcionamiento con:

```
sudo systemctl status docker
```

Finalmente, se comprobó la versión instalada mediante:

```
docker --version
```

El resultado obtenido fue:

```
Docker version 29.1.3
```

Instalación de OWASP Juice Shop

Una vez configurado Docker, se procedió a ejecutar OWASP Juice Shop dentro de un contenedor. Para ello se utilizó el siguiente comando:

```
sudo docker run -d --name juice-shop -p 3000:3000 bkimminich/juice-shop
```

Este comando permitió crear un contenedor denominado juice-shop y conectar el puerto 3000 del contenedor con el puerto 3000 de la máquina virtual. Posteriormente se verificó que el contenedor estuviera ejecutándose mediante:

```
sudo docker ps
```

El contenedor apareció activo y la aplicación pudo ser accedida desde el navegador utilizando:

localhost:3000

De esta manera se confirmó que el entorno de laboratorio estaba preparado para realizar las pruebas de seguridad.

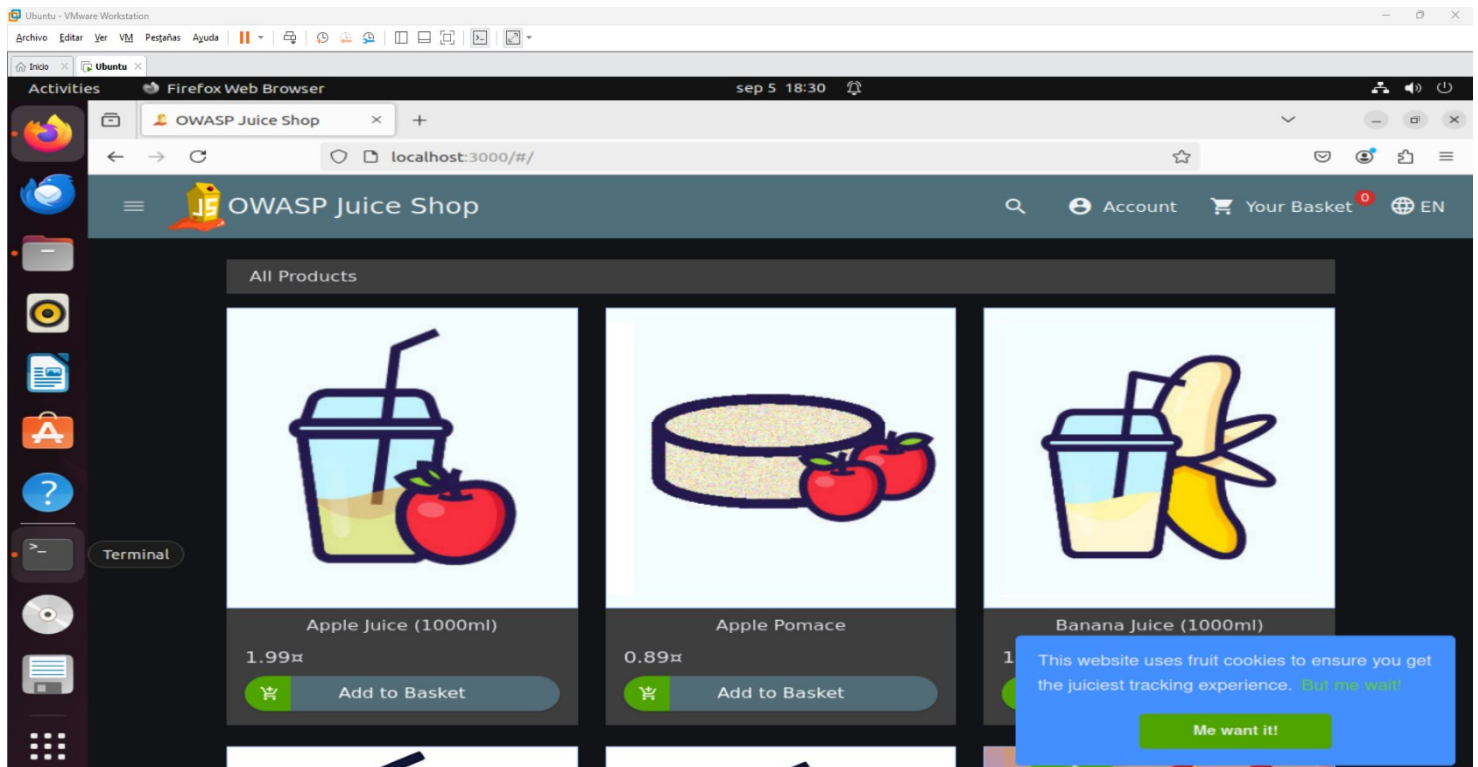


Figura 1. OWASP Juice Shop funcionando correctamente en el entorno local del laboratorio.

Metodología

Para el desarrollo de las pruebas se siguió una metodología basada en diferentes etapas:

1. **Observación:** identificación de las funcionalidades y comportamiento de la aplicación.
2. **Investigación:** revisión de información relacionada con los retos y vulnerabilidades.
3. **Formulación de la prueba:** definición de una acción o entrada que permitiera comprobar el comportamiento de la aplicación.
4. **Ejecución controlada:** realización de las pruebas únicamente sobre OWASP Juice Shop.

5. **Análisis:** evaluación del resultado obtenido y de su posible impacto.
6. **Documentación:** registro de los procedimientos y resultados.
7. **Evaluación del riesgo:** análisis básico de las posibles consecuencias.
8. **Recomendaciones:** propuesta de medidas para prevenir o reducir los riesgos identificados.

Vulnerabilidad / Prueba 1: Password Strength

Identificación

La primera prueba estuvo relacionada con la seguridad de las credenciales y la fortaleza de las contraseñas. Dentro del Score Board de OWASP Juice Shop se identificó el reto Password Strength, perteneciente a la categoría Broken Authentication. El objetivo fue analizar el riesgo asociado al uso de una contraseña débil en una cuenta administrativa.

Prueba inicial

Como referencia, se realizó primero un intento de autenticación utilizando credenciales incorrectas:

Correo: *test@example.com*

Contraseña: *incorrecta123*

La aplicación respondió:

Invalid email or password

Este comportamiento sirvió como referencia antes de realizar la prueba.

Desarrollo de la prueba

A partir de las pistas proporcionadas por el propio reto, se analizó la posibilidad de que la cuenta administrativa utilizara una contraseña débil. La cuenta analizada correspondía al administrador:

admin@juice-shop.op

Durante la prueba se identificó que la contraseña utilizada era:

admin123

Con estas credenciales fue posible iniciar sesión correctamente en la cuenta administrativa.

Resultado obtenido

La prueba demostró que una contraseña sencilla y predecible puede representar un riesgo importante cuando es utilizada por una cuenta con privilegios administrativos.

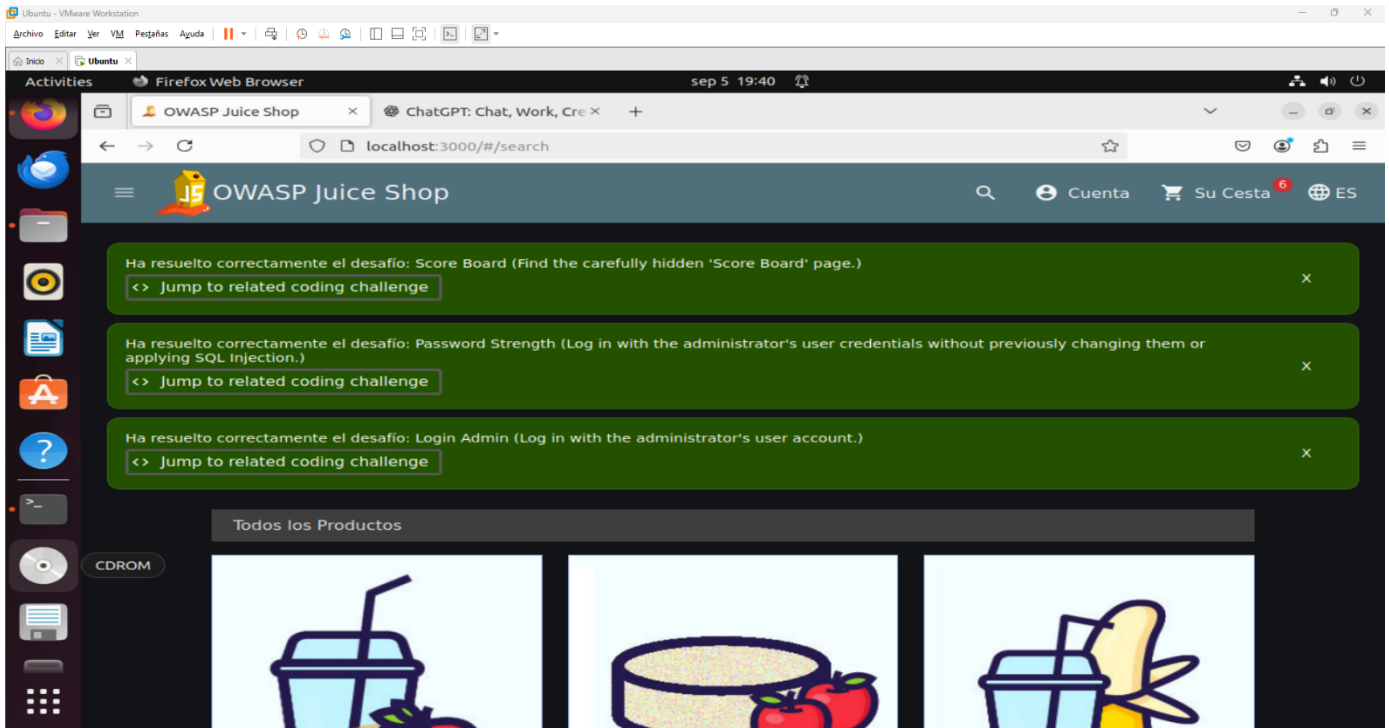


Figura 2. Acceso exitoso a la cuenta administrativa utilizando una contraseña débil.

Análisis del riesgo

El uso de contraseñas débiles representa un riesgo debido a que pueden ser descubiertas mediante técnicas de adivinación, ataques automatizados o listas de contraseñas comunes. El riesgo aumenta cuando la contraseña pertenece a una cuenta administrativa, debido al nivel de privilegios asociado a dicha cuenta. En un sistema real, el compromiso de una cuenta administrativa podría permitir el acceso no autorizado a información, configuraciones y funcionalidades sensibles.

Recomendaciones

Para reducir este riesgo se recomienda:

- Utilizar contraseñas largas y difíciles de predecir.
- Evitar contraseñas comunes o relacionadas con palabras conocidas.
- Implementar políticas de contraseñas seguras.
- Utilizar autenticación multifactor cuando sea posible.
- Limitar los intentos de inicio de sesión.
- Revisar periódicamente las cuentas con privilegios administrativos.

Vulnerabilidad / Prueba 2: SQL Injection

Identificación

La segunda prueba correspondió a una vulnerabilidad de SQL Injection, ubicada dentro de la categoría Injection de OWASP Juice Shop. SQL Injection ocurre cuando una aplicación incorpora de manera insegura datos proporcionados por el usuario dentro de consultas SQL. Esto puede permitir que una entrada manipulada modifique el comportamiento esperado de una consulta.

Prueba inicial

Como referencia se realizó nuevamente un intento de autenticación utilizando credenciales incorrectas:

Correo: *test@example.com*

Contraseña: *incorrecta123*

La aplicación respondió:

Invalid email or password

Este resultado permitió establecer el comportamiento normal del formulario antes de realizar la prueba.

Realización de la prueba

Para comprobar el comportamiento del formulario se utilizó una entrada diseñada para evaluar si el campo de correo electrónico era vulnerable a SQL Injection.

En el campo de correo se introdujo:

`'OR 1=1--`

En el campo de contraseña se utilizó:

`123`

La aplicación procesó la entrada de manera insegura y permitió el acceso a la cuenta administrativa.

Resultado obtenido

La prueba fue exitosa y permitió acceder a la cuenta administrativa sin proporcionar una contraseña válida. Este resultado demostró que la aplicación vulnerable no estaba validando y procesando correctamente la entrada proporcionada por el usuario.

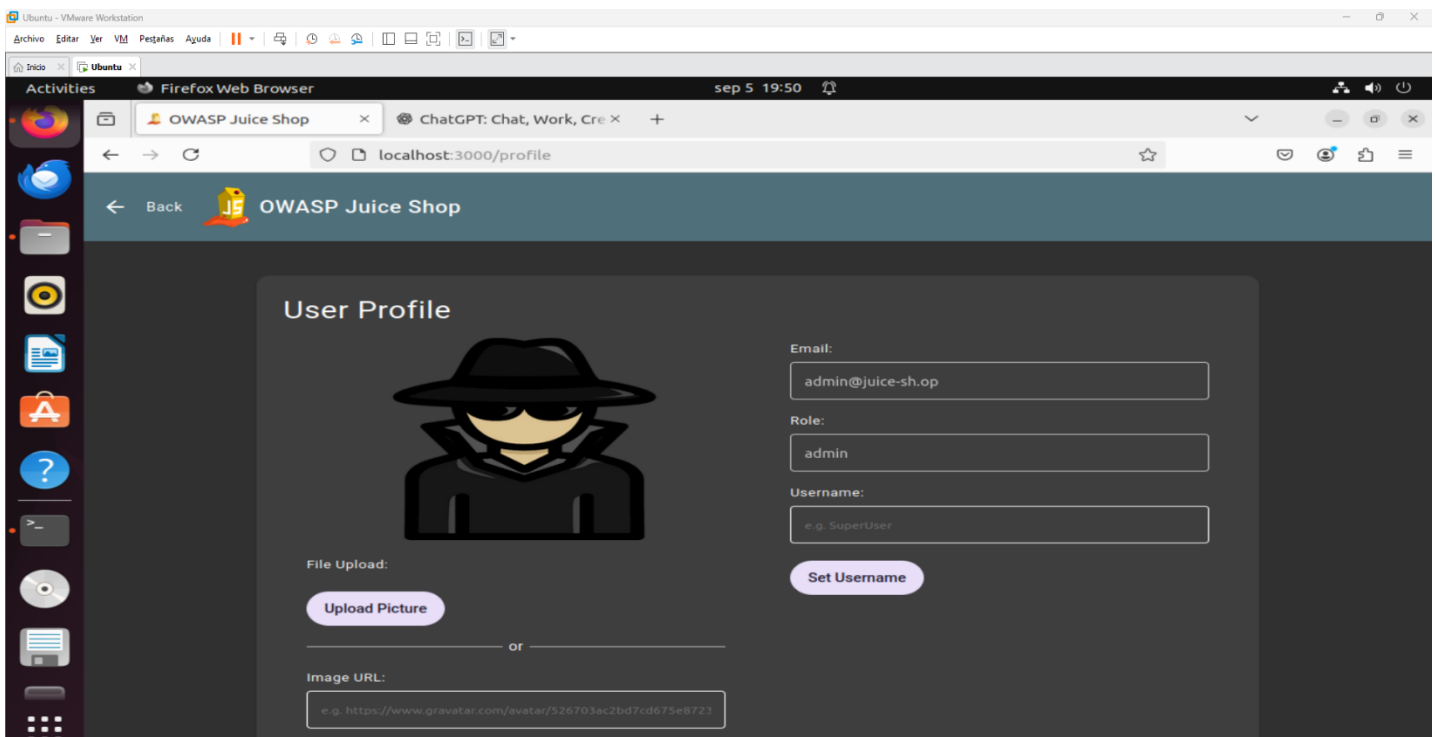


Figura 3. Acceso a la cuenta administrativa como resultado de la prueba de SQL Injection.

Análisis del riesgo

SQL Injection puede representar un riesgo alto para una aplicación web debido a que, dependiendo de la implementación vulnerable, podría permitir modificar consultas, acceder

a información no autorizada, alterar datos o evadir mecanismos de autenticación. En este laboratorio se comprobó específicamente la posibilidad de evadir el proceso de autenticación y acceder a una cuenta administrativa.

Recomendaciones

Para prevenir este tipo de vulnerabilidad se recomienda:

- Utilizar consultas SQL parametrizadas.
- Evitar construir consultas mediante concatenación directa de entradas del usuario.
- Validar correctamente los datos recibidos.
- Aplicar el principio de mínimo privilegio a las cuentas de base de datos.
- Implementar mecanismos de monitoreo y registro.
- Realizar pruebas de seguridad durante el desarrollo de las aplicaciones.

Vulnerabilidad / Prueba 3: Improper Error Handling

Identificación

La tercera prueba correspondió al reto Error Handling, ubicado en la categoría Security Misconfiguration dentro de OWASP Juice Shop. El manejo incorrecto de errores puede generar riesgos cuando una aplicación proporciona información innecesaria sobre su funcionamiento interno o responde de manera insegura ante entradas o condiciones inesperadas.

Realización de la prueba

Durante la exploración controlada de las funcionalidades de OWASP Juice Shop y la inspección de las solicitudes HTTP realizadas por la aplicación mediante las herramientas de desarrollo del navegador, se produjo una condición de error que activó el reto Error Handling. Posteriormente, el resultado fue verificado desde el Score Board de la aplicación. La prueba se realizó únicamente dentro del laboratorio local.

Resultado obtenido

El reto apareció como resuelto dentro del Score Board de OWASP Juice Shop.

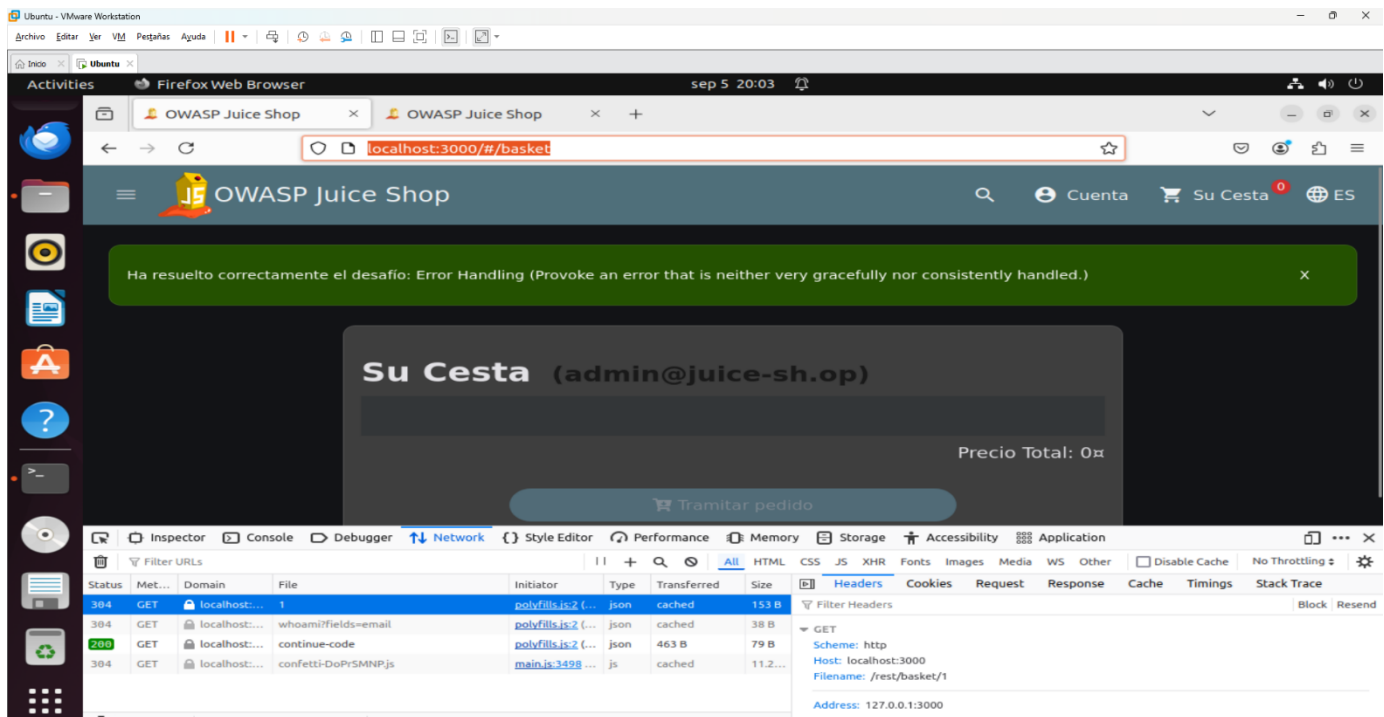


Figura 4. Verificación del reto Error Handling como completado dentro del Score Board.

Análisis del riesgo

Un manejo inadecuado de errores puede revelar información sobre la estructura interna de una aplicación, sus componentes o la forma en que procesa determinadas solicitudes. Dependiendo de la información expuesta, un atacante podría utilizar estos datos para comprender mejor el funcionamiento del sistema y preparar ataques posteriores. Por esta razón, los errores deben manejarse de manera controlada y evitar la exposición innecesaria de información técnica.

Recomendaciones

Se recomienda:

- Evitar mostrar información técnica innecesaria al usuario final.
- Implementar mensajes de error generales para los usuarios.
- Registrar los detalles técnicos en sistemas internos de monitoreo.

- Validar correctamente los datos recibidos.
- Probar el comportamiento de la aplicación ante entradas inesperadas.
- Revisar las configuraciones de producción antes de publicar una aplicación.

Conclusiones

El desarrollo de este laboratorio permitió comprender de manera práctica algunos conceptos fundamentales relacionados con la seguridad de aplicaciones web. La utilización de OWASP Juice Shop dentro de una máquina virtual con Ubuntu y Docker permitió crear un entorno controlado en el cual fue posible realizar pruebas sin afectar sistemas externos. Durante el proyecto se analizaron diferentes situaciones de seguridad. En la primera prueba se identificó el riesgo asociado al uso de una contraseña débil en una cuenta administrativa. En la segunda se comprobó una vulnerabilidad de SQL Injection que permitió evadir el proceso de autenticación y acceder a una cuenta administrativa. Finalmente, se analizó el reto Error Handling, relacionado con el manejo inadecuado de errores dentro de la aplicación.

Además de identificar vulnerabilidades, el laboratorio permitió comprender que una prueba de seguridad no consiste únicamente en ejecutar comandos o introducir datos. Es necesario observar el comportamiento de la aplicación, investigar, formular una hipótesis, realizar una prueba controlada, analizar los resultados y documentar la evidencia obtenida. El proyecto también permitió fortalecer conocimientos básicos de Linux, Docker, aplicaciones web, autenticación, inyección SQL, manejo de errores y análisis de riesgos. La experiencia demuestra que la ciberseguridad tiene tanto una dimensión técnica como organizacional, ya que una vulnerabilidad puede terminar afectando la información, los procesos y la continuidad de una organización. Este proyecto representa un primer paso en mi formación práctica en ciberseguridad y me permitió pasar de la comprensión teórica de algunas vulnerabilidades a su identificación y análisis dentro de un entorno de laboratorio.

Aprendizajes obtenidos

Durante el desarrollo del laboratorio adquirí conocimientos tanto técnicos como analíticos relacionados con la ciberseguridad. Uno de los principales aprendizajes fue comprender la importancia de trabajar en entornos controlados al realizar pruebas de seguridad. La utilización de VMware, Ubuntu, Docker y OWASP Juice Shop permitió practicar sin poner

en riesgo sistemas o información de terceros. También fortalecí mis conocimientos básicos de Linux, especialmente en el uso de la terminal, instalación de paquetes, administración de servicios y ejecución de comandos. El proyecto me permitió comprender mejor el funcionamiento de Docker y los contenedores, así como su utilidad para crear entornos de prueba de manera rápida y organizada.

Desde el punto de vista de seguridad, aprendí a reconocer conceptos como Broken Authentication, SQL Injection y manejo inadecuado de errores, comprendiendo que una vulnerabilidad no debe analizarse únicamente desde el punto de vista técnico, sino también considerando su posible impacto sobre la información y los procesos de una organización. Otro aprendizaje importante fue la necesidad de documentar cada prueba. Las evidencias, los resultados y las explicaciones permiten demostrar qué se hizo, qué se encontró y por qué el hallazgo puede representar un riesgo. Finalmente, comprendí que el análisis de ciberseguridad requiere una combinación de observación, investigación, pensamiento crítico, práctica técnica y capacidad para comunicar los resultados.

Próximos pasos

Este laboratorio representa una primera experiencia práctica dentro de mi formación en ciberseguridad. Como siguientes pasos, considero importante continuar desarrollando conocimientos técnicos y ampliar progresivamente la dificultad de los proyectos.

Entre mis próximos objetivos se encuentran:

- Continuar practicando vulnerabilidades de aplicaciones web.
- Conocer herramientas utilizadas en pruebas de seguridad.
- Aprender fundamentos de redes y protocolos.
- Fortalecer conocimientos de Linux.
- Continuar utilizando Docker y otros entornos de laboratorio.
- Aprender sobre análisis de vulnerabilidades y gestión de riesgos.
- Explorar conceptos relacionados con seguridad empresarial.

- Desarrollar proyectos que relacionen ciberseguridad con Recursos Humanos y gestión organizacional.
- Documentar nuevos laboratorios para construir un portafolio profesional.

A largo plazo, estos proyectos pueden ayudarme a desarrollar una visión más completa de la ciberseguridad, combinando conocimientos administrativos, gestión de riesgos, tecnología y seguridad de la información.